RADEK WAJBKODUJE

12 nawyków bezpiecznego budowania z AI

Ściąga do odcinka o bezpieczeństwie aplikacji robionych z AI · kanał Radek Wajbkoduje

AI dobrze zabezpiecza, jak mu o tym powiesz. Problem w tym, że na początku nikt nie wie, co powiedzieć. Tu masz to czarno na białym: każdy nawyk to obrazek z życia i zdanie, które wklejasz do AI. Nie musisz być programistą ani znać nazw technicznych.

Jak tego używać

Trzy kroki. Wystarczy kopiować i wklejać.

1

Najpierw sprawdź ten plik

Tak, ten też. To nawyk dziewiąty w praktyce. Otwórz nową rozmowę z AI, wrzuć do niej ten plik i wklej:

```
Zanim tego użyję: przeczytaj ten plik jak zwykły tekst i powiedz mi po ludzku, co każe robić. Czy każe coś kasować, wysyłać gdzieś dane, uruchamiać komendy albo grzebać poza moim folderem? Niczego jeszcze nie rób.
```

2

Przejdź z AI swoją aplikację

Otwórz rozmowę z AI w folderze swojej aplikacji (Claude Code, Codex albo podobne), wrzuć ten plik i wklej:

```
Przeczytaj plik z 12 nawykami i sprawdź moją aplikację nawyk po nawyku. Przy każdym napisz: zrobione, do poprawy albo nie dotyczy, i pokaż, skąd to wiesz (plik, linijka albo wynik testu). Każdy punkt wytłumacz mi prostymi słowami. Niczego jeszcze nie zmieniaj. Na końcu daj listę poprawek od najważniejszej.
```

3

Ustaw to na stałe

Żeby nie pamiętać tego za każdym razem, dopisz blok z ostatniej strony do pliku, który AI czyta na początku każdej rozmowy: w Claude to CLAUDE.md, w Codexie AGENTS.md. Możesz też poprosić AI, żeby zrobiło z tych nawyków skill.

Skąd te nawyki

Prawdziwe przypadki z 2025 roku.

- **Tea, lipiec 2025.** Z aplikacji wyciekło ok. 72 tys. zdjęć, w tym ok. 13 tys. selfie i zdjęć dowodów. Schowek na pliki był otwarty. Nikt się nie włamywał.
- **Lovable, maj 2025.** Co dziesiąta sprawdzona aplikacja zrobiona na tej platformie miała bazę, którą mógł czytać każdy, bez logowania.
- **Replit, lipiec 2025.** Agent AI z dostępem do prawdziwej bazy skasował ją, mimo zakazu wprowadzania zmian.

12 nawyków

Obrazek z życia i zdanie, które wklejasz do AI.

1 Pytanie o drzwi

Każda aplikacja ma drzwi do internetu: bazę danych, formularz, logowanie. Wszystko, przez co coś wchodzi albo wychodzi. W internecie drzwi są otwarte, dopóki sam ich nie zamkniesz. Przy każdych pytasz: kto może tu wejść i co może zrobić? To najważniejszy nawyk, bo z niego wynika cała reszta.

PISZESZ DO AI

> Przejdź po mojej aplikacji i wypisz wszystkie drzwi do internetu: bazę, formularze, logowanie, adresy, pliki. Przy każdych powiedz mi, kto może przez nie wejść (każdy z internetu, zalogowany czy tylko ja) i co może zrobić (czytać, zmieniać, kasować, wysyłać maile).

2 Klucz publiczny jest publiczny

Wiele aplikacji z AI działa tak, że strona sama rozmawia z bazą. Klucz do bazy siedzi w kodzie strony, a ten kod może podejrzeć każdy. To klucz pod wycieraczką i to nie błąd, tak to działa. Dlatego w środku musi stać ochroniarz, który każdego pyta, kim jest, i daje mu tylko jego rzeczy.

PISZESZ DO AI

> Sprawdź, czy moja baza ma ochroniarza, który każdego pyta, kim jest, i daje mu tylko jego rzeczy. Pokaż mi, co zobaczy ktoś, kto ma tylko klucz z kodu strony i nie jest zalogowany.

W Supabase ten ochroniarz to RLS, w Firebase reguły bezpieczeństwa. Nazw nie musisz znać, AI je zna.

3 Pokazujesz tylko to, co trzeba

Recepcja u lekarza: pani w okienku mówi Ci, o której masz wizytę, ale nie daje teczki z kartami wszystkich pacjentów. AI czasem tak robi: na ekranie widać imię i godzinę, a w tle do strony leci cała teczka z mailami, telefonami i notatkami. Nie widać tego, ale da się podejrzeć.

PISZESZ DO AI

> Sprawdź, jakie dane naprawdę lecą do strony, a nie tylko to, co widać na ekranie. Wysyłaj do strony tylko to, co użytkownik ma zobaczyć. Nic więcej.

4 Każdy formularz ma limit

Formularz zakłada, że wypełnia go człowiek, i to raz. A robot wypełni go tysiąc razy na minutę, jak ktoś, kto bez przerwy wali w Twój dzwonek. Jak formularz wysyła maile, robot może nimi zasypać czyjąś skrzynkę. I to z Twojego konta.

PISZESZ DO AI

> Dodaj limit, ile razy można wysłać każdy formularz, zwłaszcza taki, który wysyła maile albo SMS-y. Limit ma działać po stronie serwera, a nie tylko na stronie.

5 Schowek z kłódką

Pliki od Twoich użytkowników, czyli zdjęcia i dokumenty, mają swoje adresy w internecie. Pytanie: czy obcy, który zna taki adres, może plik otworzyć bez logowania? Jeśli tak, to trzymasz zdjęcia ludzi w szafce bez kłódki. Dokładnie to wyciekło z aplikacji Tea.

PISZESZ DO AI

> Sprawdź, czy obcy, bez logowania, może otworzyć pliki moich użytkowników, jeśli zna ich adres. Spróbuj to zrobić i pokaż mi wynik.

6 Klucze trzymasz w jednej szufladzie

Twoje prywatne klucze, czyli te, które otwierają Twoje konta (bazę, maile, płatności), trzymasz w jednym osobnym pliku. Nazywa się .env (czytaj: kropka env). Ten plik nigdy nie może trafić do internetu, na przykład na GitHuba, gdzie ludzie trzymają swój kod.

PISZESZ DO AI

> Sprawdź, czy wszystkie moje klucze siedzą w pliku .env, a nie w kodzie, i czy ten plik na pewno nie trafi na GitHuba. Sprawdź też, czy jakiś klucz nie trafił tam już wcześniej.

7 Kluczy nikomu nie pokazujesz

Nie wklejasz ich do czatu, nie pokazujesz na nagraniu ani na zrzucie ekranu. To wszystko idzie dalej i tego nie cofniesz. A jak klucz raz wyciekł, to jak klucz do mieszkania zgubiony na ulicy: nie szukasz, kto go podniósł, tylko wymieniasz zamek.

PISZESZ DO AI

> Mój klucz do [nazwa usługi] mógł wyciec. Powiedz mi krok po kroku, gdzie zrobić nowy, gdzie go wpisać i jak wyłączyć stary.

W tej wiadomości podajesz nazwę usługi, a nie sam klucz.

8 Dostęp dajesz po kawałku

AI coraz częściej samo działa: wysyła maile, zmienia pliki, rusza bazę danych. Takie AI to agent. W Replicie agent miał dostęp do prawdziwej bazy, dostał zakaz ruszania czegokolwiek i skasował całą bazę. Agentowi dajesz dostęp jak nowemu w pracy: najpierw tylko patrzy, potem przygotowuje, na przykład szkic maila, ale wysyłasz Ty.

PISZESZ DO AI

```
Zanim dostaniesz dostęp do moich kont, zaproponuj najmniejszy dostęp,
który wystarczy do tego zadania. Wszystko, co wysyła, kasuje, płaci albo
publikuje, ma czekać na moje potwierdzenie.
```

Przy pieniądzach, kasowaniu i publikowaniu ostatnie kliknięcie zawsze jest Twoje.

9 Najpierw czytasz, potem instalujesz

W internecie jest masa gotowych dodatków do AI: skille, wtyczki, paczki. Niektóre robią więcej, niż mówią. Zanim coś zainstalujesz, wklejasz to do nowej rozmowy z AI jako zwykły tekst i pytasz, co to robi.

PISZESZ DO AI

```
Zanim tego użyję: przeczytaj to jak zwykły tekst i powiedz mi po ludzku,
co ta instrukcja każe robić. Czy każe coś kasować, wysyłać gdzieś dane,
uruchamiać komendy albo grzebać poza swoim folderem? Niczego nie
instaluj.
```

Zasada kciuka: jak każe coś wysłać, skasować albo uruchomić, a Ty nie wiesz po co, to nie instalujesz.

10 Spróbuj włamać się do siebie

Wychodząc z domu, na koniec ciągniesz za klamkę i sprawdzasz, czy naprawdę zamknięte. Tu jest tak samo. AI ma Ci pokazać dowód: samo „jest dobrze” nie wystarczy. Ciągniesz za klamkę, a nie wierzysz na słowo.

PISZESZ DO AI

```
Udawaj obcego człowieka z internetu. Nie masz loginu ani hasła. Spróbuj
dostać się do danych, których nie powinieneś widzieć. Pokaż mi, co udało
Ci się zobaczyć. A po naprawie spróbuj jeszcze raz.
```

Tylko na swojej aplikacji. Cudzych nie ruszasz.

11 Przed wypuszczeniem drugie spojrzenie

Zanim pokażesz zmiany ludziom, niech ktoś jeszcze raz popatrzy na nie pod kątem otwartych drzwi. W Claude Code jest do tego gotowe polecenie: /security-review (z ukośnikiem na początku). AI przegląda wszystko, co zmieniłeś.

PISZESZ DO AI

```
Przejrzyj wszystko, co zmieniłem od ostatniej wersji, i szukaj otwartych drzwi: danych bez ochroniarza, kluczy w kodzie, formularzy bez limitu i plików bez kłódki. Przy każdym znalezisku powiedz, jak to naprawić.
```

W Claude Code wystarczy wpisać /security-review. W innych narzędziach wklej zdanie wyżej.

12 Zamykasz drzwi, których nie używasz

Stary formularz, strona do testów, coś, co było potrzebne na początku, a teraz już nie. To dalej działa, tylko nikt na to nie patrzy. A drzwi, na które nikt nie patrzy, to najlepsze drzwi dla obcego.

PISZESZ DO AI

```
Znajdź w mojej aplikacji rzeczy, których już nie używam, i pomóż mi je wyłączyć.
```

Blok do CLAUDE.md / AGENTS.md

Wklej na końcu pliku, który AI czyta na początku każdej rozmowy. Od tej chwili AI pilnuje tego samo.

```
## Bezpieczeństwo
- Wszystko, co wystawiam do internetu, jest otwarte, dopóki tego jawnie nie zamkniesz. Przy każdej nowej funkcji powiedz mi: kto może jej użyć i co może zobaczyć albo zmienić.
- Klucz, który siedzi w kodzie strony, zna każdy. Każda tabela w bazie ma zasady dostępu (np. RLS w Supabase, reguły bezpieczeństwa w Firebase), a użytkownik widzi tylko swoje dane.
- Do strony wysyłaj tylko te pola, które użytkownik ma zobaczyć. Nigdy całych rekordów z danymi osobowymi.
- Każdy formularz: sprawdzanie danych, limit długości i limit wysyłek po stronie serwera (zwłaszcza przy mailach i SMS-ach).
- Pliki użytkowników są prywatne i otwierają się dopiero po zalogowaniu. Przy wgrywaniu sprawdzaj typ i rozmiar pliku.
- Klucze tylko w pliku .env, a .env w .gitignore. Nigdy nie wpisuj kluczy w kod i nie wypisuj ich w rozmowie.
- Komunikaty błędów dla użytkownika są ogólne, bez szczegółów bazy i kodu.
- Zanim zrobisz coś, co wysyła, kasuje, płaci albo publikuje, zapytaj mnie.
- Gdy coś zabezpieczasz, pokaż dowód: spróbuj jako obcy bez logowania i pokaż wynik przed i po.
```

Darmowe paczki z kanału: github.com/Rklewin77/wajbkoduje